

← ↻ ☆ Incomplete Backend Data Purge and Broken Access Control in Google AI Studio / Interactions API

+1

Hotlists

Unmark Duplicate

🔔

⋮

Comments (4)Dependencies (0)Duplicates (0)Blocking (0)Resources (11)

Duplicate of 1467Customer IssueP4+ Add Hotlist

👤 STATUS UPDATE No update yet.

📄 DESCRIPTION bu...@google.com created issue on behalf of gabor_gabor@freemail.hu #1

Sep 14, 2026 10:05PM

⋮

Summary: Incomplete Backend Data Purge and Broken Access Control in Google AI Studio / Interactions API

Program: Google VRP

URL: <https://aistudio.google.com>

Vulnerability type: Permissions Bypass

Details

Please describe the technical details of the vulnerability Google AI Studio and the underlying Interactions API suffer from a critical backend data lifecycle defect and broken access control. When a user deletes a chat session via the UI, the system merely orphans the local .json metadata pointer in the Google Drive Trash. The deletion button fails to send a DELETE or DROP signal to the backend storage. Technical Reality: The backend retains 100% of the conversation state, token history, and context in active production storage, directly overriding the documented 1-day (24h) TTL auto-purge for Free Tier interactions. The restored JSON pointer acts as a persistent anchor that grants the client immediate access to the stateful backend session. Technical Evidence: Inactivity of TTL Purge: According to official Gemini API documentation, Free Tier interactions are purged automatically after 24 hours: <https://ai.google.dev/gemini-api/docs/zdr>. My forensic testing proves that data remains 100% functional and recoverable on the backend even after 5+ days. Specification vs. Implementation: There is a severe Specification-Implementation Desynchronization. Google's UI claims "permanent deletion" and "cannot be recovered," while their own backend infrastructure ensures data remains "perpetually retained." Broken Access Control: The backend fails to validate the deletion status of sessions. Restoring the pointer via Google's official Drive File Recovery tool instantly reactivates the unpurged backend session. Supporting Documentation: Interactions API Docs (TTL): <https://ai.google.dev/gemini-api/docs/zdr> Logging Policy: <https://ai.google.dev/gemini-api/docs/logs-policy> Proof of Retention: <https://github.com/istokovicsgyorgy79-jpg/CanusLupus/blob/main/552682596%20Issue%20Tracker.PDF> Forensic Reproduction: <https://github.com/istokovicsgyorgy79-jpg/CanusLupus/blob/main/557281747%20Issue%20Tracker.pdf>

Attack scenario

Impact Analysis

1. Systemic GDPR Article 17 Violation: The UI explicitly promises "permanent deletion" and that the data "cannot be recovered." In reality, Google illegally retains and stores private prompts and chat history on their production servers after a formal deletion request. This is a systemic GDPR non-compliance fraud.
2. Persistent Information Disclosure: Because the backend never executes a hard-purge, any actor who recovers the client-side JSON pointer (via local access, backups, or synchronization logs) can resurrect the entire conversation history, context window, and sensitive tokens. This exposes users to data leakage long after they have attempted to securely purge their sensitive interactions.

Reporter  gabor_gabor@freemail.hu

Type  Customer Issue

Priority P4

Severity S4

Status Duplicate of 1467

Access Default access View

Expanded Access?

Assignee

Verifier

Collaborators  ^

CC  gabor_gabor@freemail.hu
wo...@google.com
Un-CC me

Code Changes --

Pending Code Changes --

Disclosure information --

Reporter e-mail --

Requested charity --

Found In --

Targeted To --

3. Intentional Architecture vs. Deceptive UI: Google’s own security team previously closed reports on this defect as "Intended Behavior," formally admitting that data is intentionally kept on backend systems to allow for recovery. This contradicts the UI's explicit "cannot be recovered" warnings, confirming a deceptive "Placebo Deletion" design pattern used to mislead users regarding their actual data lifecycle.
4. Security Surface Expansion: The platform’s refusal to execute a backend purge extends the attack surface, ensuring that sensitive prompts remain "immortal" orphans on production storage, making them perpetually vulnerable to unauthorized retrieval and persistent session hijacking.

Report Analysis

Note: The feedback below was generated as part of an automated analysis of the submitted report. It is *NOT* part of the report that was submitted by the user.

Intended Behavior

The reported behavior appears to be intended. Please check the documentation.

 **Képernyőkép 2026-09-11 202017.png**

⋮

260 KB [View](#) [Download](#) 

COMMENTS

All comments

▼

↓ Oldest first



sp...@google.com <sp...@google.com> [#2](#)

Sep 14, 2026 10:05PM

⋮

NOTE: This is an automatically generated email

Hi! Many thanks for sharing your report.

This email confirms we've received your message. We'll investigate the issue you've reported and get back to you once we have an update. In the meantime, you might want to take a look at the [list of frequently asked questions about Google Bug Hunters](#).

Also, if you have not already done so, create a profile on [the Google Bughunters site](#) if you'd like us to publicly recognize your contribution:

- [Leaderboard](#) – You'll be added here if we issue a reward for your report.
- [Honorable Mentions](#) – You'll be added here if you are not in the Hall of Fame, but we file a security vulnerability bug based on your report.

Note that we only act on reports concerning vulnerabilities or technical security problems in one of our products. This is not the correct channel if you need to resolve a problem with your account, or want to report non-security bugs or suggest a new product feature.

Hey! Our automation saw that your report contained a link to github.com! Did you know that you can get rewarded for patching vulnerabilities? See our [Patch Rewards Program](#) for more information!

Cheers,
Google Security Bot

[Follow us](#) on Twitter!



Sep 14, 2026 10:09PM ⋮

Status: Duplicate of [1467](#).

Hi! We've analyzed your report and want to let you know that **it is a duplicate of an existing bug** that we've already received. For this reason, we're closing this issue.

Unfortunately, this also excludes your report from our reward program – duplicate submissions don't qualify for reward or credit. Best of luck in your future bug hunting!

Thanks again for your report and time,
Google Security Bot



gabor_gabor@freemail.hu <gabor_gabor@freemail.hu> [#4](#)

Sep 14, 2026 10:15PM ⋮

CRITICAL OBJECTION AGAINST AUTOMATED CLOSURE:

1. Illegal Automated Decision-Making (GDPR Article 22 Violation):

The summary closure of this security and privacy defect ticket by an automated analysis/bot without human intervention is strictly ILLEGAL under Regulation (EU) 2016/679 (GDPR) Article 22. As the affected party, I explicitly demand a substantive, manual review by a human security engineer. Algorithmic dismissal of a documented data lifecycle fraud is a direct compliance violation.

2. Specification-Implementation Failure:

This specific report contains and references Google's OWN official developer documentation and public API specifications regarding TTL and Zero Data Retention (ZDR) rules. The backend's refusal to purge the stateful Interactions API prompts directly contradicts your own corporate documentation.

You cannot label a failure to implement your own documented security specifications as "Intended Behavior." A human engineering audit is legally and technically required immediately.

VINCE/CERT-CC International Tracking ID: VRF#26-09-MTNJR.

 **VINCE.pdf**



294 KB [View](#) [Download](#) 